

Skillbox

# Защита учётных данных

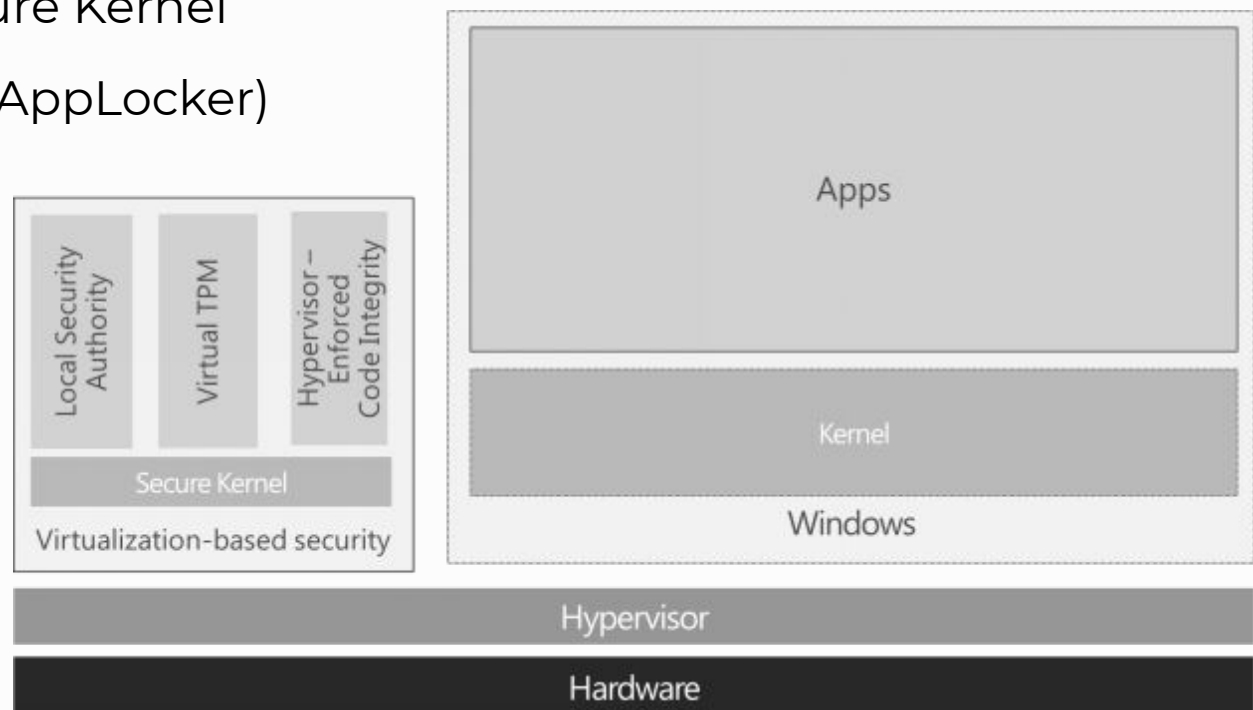
**Андрей Камардин**

Системный администратор, консультант  
по внедрению серверных ОС

# Технические контрмеры при краже учётных данных

## Windows 10 с Credential Guard:

- Ограничения на запуск в UEFI (Secure Boot)
- Виртуализация для Secure Kernel
- Контроль приложений (AppLocker)



# **Технические контрмеры при краже учётных данных**

## **Ограничение учётных записей администраторов:**

- Запрет на вход на рабочие станции
- Вторичные аккаунты для повседневных задач
- Запрет на создание задач от имени учётных записей администраторов
- По возможности отключить всех локальных администраторов
- Запрет на удалённый доступ

# Технические контрмеры при краже учётных данных

## Ограничить входящий сетевой трафик:

- Ограничение на рабочих станциях, разрешить трафик с проверенных внутренних ресурсов

### Domain Profile

- ✓ Windows Firewall is on.
- ✗ Inbound connections that do not match a rule are blocked.
- ✓ Outbound connections that do not match a rule are allowed.

### Private Profile is Active

- ✓ Windows Firewall is on.
- ✗ Inbound connections that do not match a rule are blocked.
- ✓ Outbound connections that do not match a rule are allowed.

### Public Profile

- ✓ Windows Firewall is on.
- ✗ Inbound connections that do not match a rule are blocked.
- ✓ Outbound connections that do not match a rule are allowed.

➡ [Windows Firewall Properties](#)

# **Технические контрмеры при краже учётных данных**

**Запрет на работу в интернете с учётной записью  
администратора**

**Удаление учётных записей администраторов  
из групп Администраторы**

# **Технические контрмеры при краже учётных данных**

## **Снижение количества администраторов в сети:**

- Развёртывание нового ПО не требующего административных прав
- Проверка работы старого ПО без привилегий

## **Обновление ПО**

## **Отключение LM (Lanman)**

## **Перезагрузка после выхода из системы**

# Определение атак на учётные данные

## Сбор и анализ событий на рабочих станциях:

- Запуск новых процессов (ID 4688)
- Успешный вход в систему (ID 4624)
- Вход с учётными данными (ID 4648)

## Анализ событий на контроллере домена:

- Kerberos (ID 4769, 4768, 4776)
- Вход на рабочих станциях

## Другие события

- использование NTLM
- ошибки Credential Guard

# Реагирование на подозрительную активность

## **Регулярное обновление и мониторинг:**

Снижение количества ложноположительных срабатываний

## **Обновление механизмов выявления и мониторинга:**

После каждого события безопасности или компрометации  
для улучшения защиты

## **Наблюдение за затронутыми хостами:**

Атакующий не сохранил доступ



# Реагирование на подозрительную активность

## **Выполнение плана по восстановлению:**

Полная отработка по векторам атаки

## **Отложенное выполнение плана по восстановлению:**

Выявление целей атаки, отслеживание поведения атакующего

# Меры по восстановлению

**Восстановление из резервной копии не поможет:**

Неизвестно, когда было проникновение

**Восстановление учётных записей:**

- Смена пароля при следующем входе
- Ручная смена паролей
- Сбор аккаунта рабочей станции, если скомпрометирована рабочая станция
- Полное удаление учётной записи из AD DS

**Эти меры, скорее всего, укажут атакующему, что он был обнаружен**

**Спасибо  
за внимание!**